Incident Report: MySQL Ransom Attack on corp-retail-group

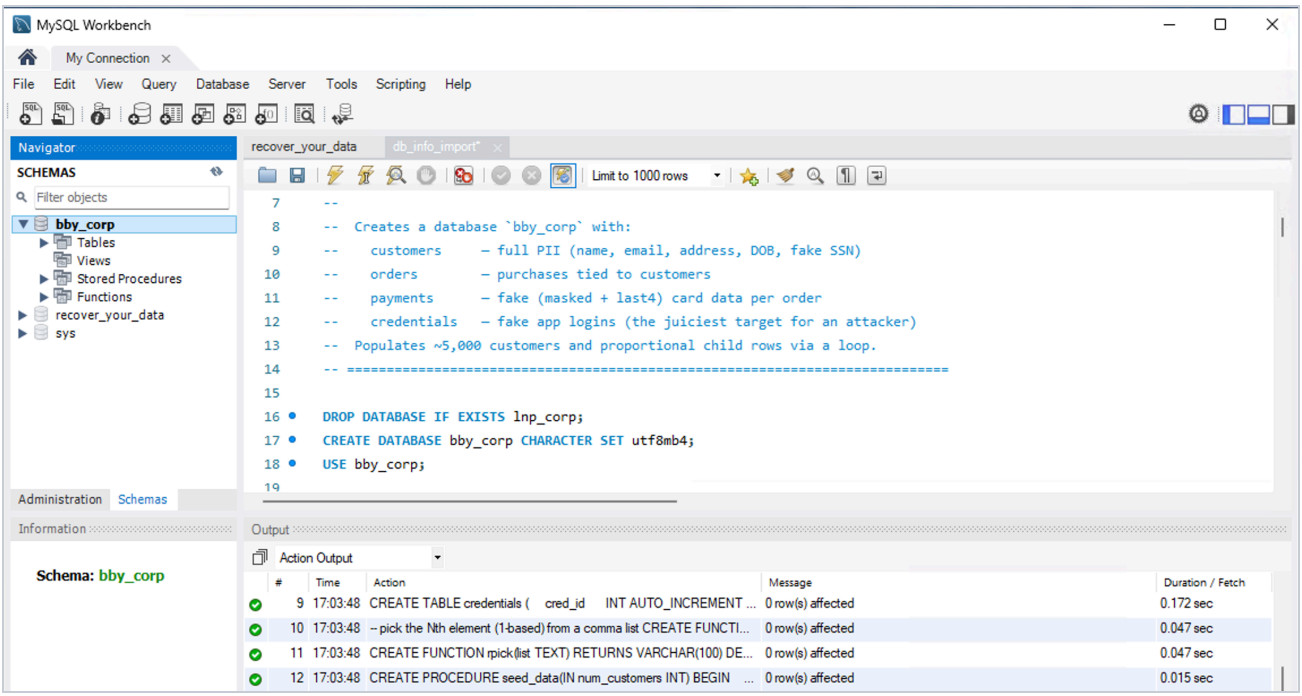
Times are US Eastern (UTC-4), as shown in the Defender portal. Date literals inside KQL are UTC (Oct 12 00:10 Eastern = 04:10 UTC). The MySQL audit exports contain every row twice; counts are de-duplicated.

1. Executive Summary

An external attacker took over the internet-exposed MySQL server on host corp-retail-group and held its data for ransom. After days of automated probing of the root, admin and sa accounts (every logged failure was a passwordless attempt), the attacker logged in as root with a credential that worked first time, left a ransom note demanding 0.0101 bitcoin within 48 hours, deleted the bby_corp database (plus the sample databases sakila and world), purged the server's binary logs and shut MySQL down at 00:11 on Oct 12, 2026. The attacker's claim that data was copied first is **not confirmed** by the logs. Root logins from attacker-linked addresses continued through Oct 17, and the same server also faced heavy Remote Desktop password guessing against its Windows administrator account.

2. Incident Details

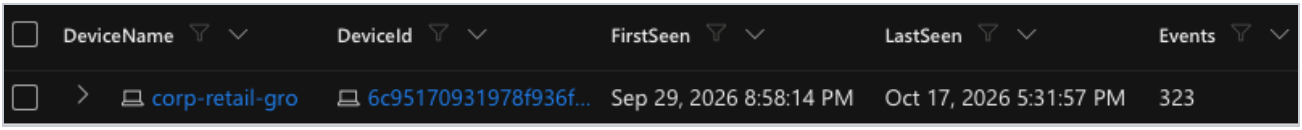
Field	Detail
Earliest malicious event in logs	Oct 7, 2026 20:54 – first connection attempt to the host from the 64.89.163.x range (Defender network events). First MySQL login attempt: Oct 10, 2026 20:19 from 77.90.185.30 (MySQL audit).
Destructive activity	Oct 12, 2026 00:10:43 – 00:11:01
Reporter	Jervon Stephen, Analyst
Classification	Database extortion (ransom note + data destruction) following unauthorized remote root access; no file encryption observed
Severity	High (proposed)
Affected assets	Host corp-retail-group (MySQL audit; Defender shows the name truncated as corp-retail-gro); MySQL 8.0 service; databases bby_corp, sakila, world (all deleted)
Environment note	Lab environment. The binary log name josh-mde-lab-bin and Azure guest-agent files indicate a cloud lab VM, and the database was built from a seed script with synthetic customer, order, payment and credential data.



Lab seed script: builds the database with synthetic customer, order, payment and credential data.

KQL – confirm Defender coverage of the MySQL host

```
DeviceNetworkEvents
| where DeviceName startswith "corp-retail-gro"
| where InitiatingProcessFileName =~ "mysqld.exe"
| summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), Events=count() by DeviceName,
DeviceId
```

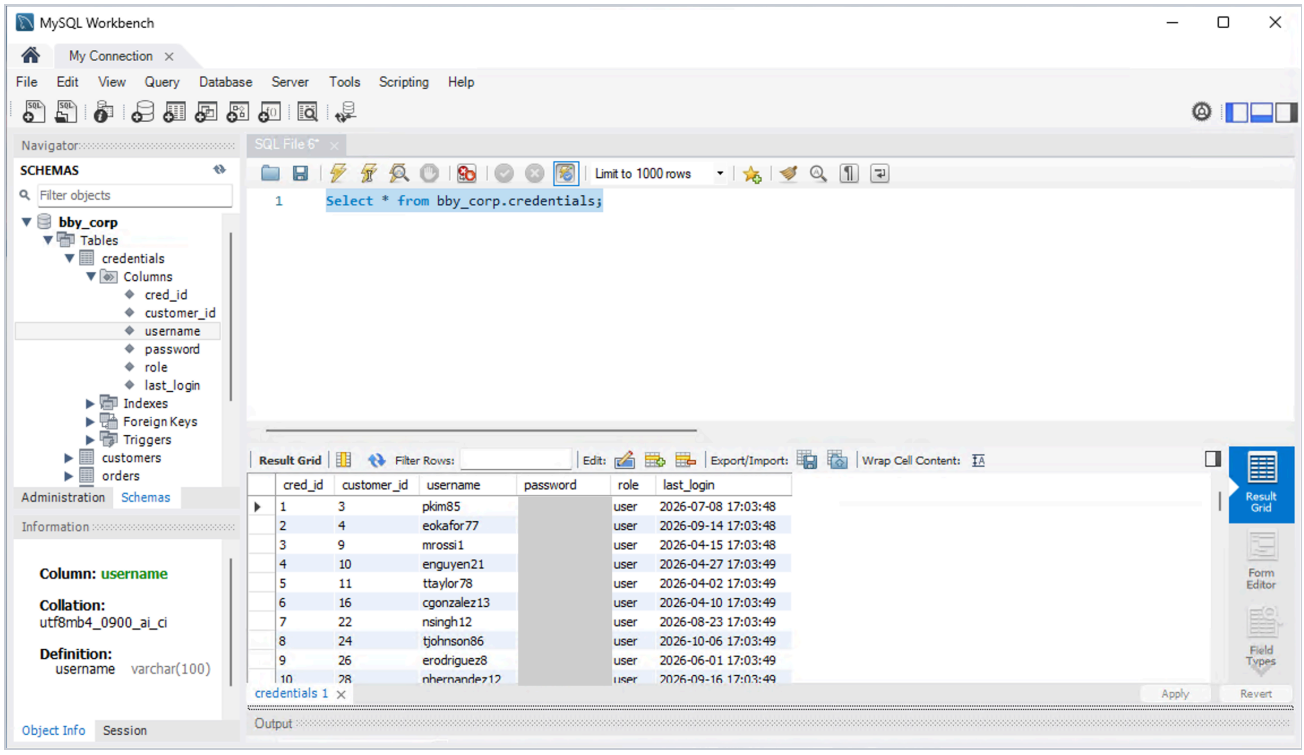


Defender recorded 323 mysqld network events from Sep 29 to Oct 17, so it covers the whole incident.

3. Impact Assessment

Area	Finding
Confidentiality	Attacker had full root access and surveyed all three databases before deleting them, using table-size and column-metadata queries. **No data reads were logged:** the audit log, which covers Oct 10 19:52 onward, contains no queries against business tables, so the ransom note's claim that the data was copied is unsupported. Defender network telemetry covers the attack window and shows no outbound connection from mysqld to a public address. It records connections, not bytes, so theft over an inbound MySQL session cannot be fully excluded, and a direct copy of the data files would not appear in MySQL's query log.
Integrity	DROP DATABASE on three databases; root privileges revoked and re-granted; PURGE BINARY LOGS and RESET MASTER erased binary log history.
Availability	SHUTDOWN issued Oct 12 00:11:01. Service reachable again by Oct 12 18:23.

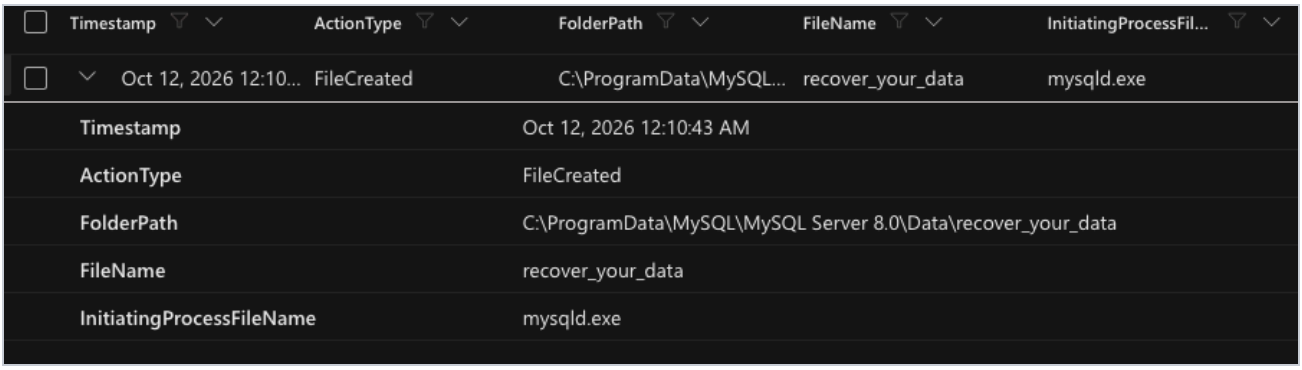
Scope	One database server. Defender process, file and registry data show no ransomware binary, file encryption or new persistence.
Business impact	**Data loss and downtime.** The bby_corp database was deleted, and MySQL was down for up to about 18 hours (shut down Oct 12 00:11, next logon 18:23). Because the binary logs were purged, recovery depends entirely on the last backup, and anything written since then is lost. **Trust.** The attacker kept root access for five more days, so the server should be treated as untrusted until rebuilt and every credential is rotated. **Legal exposure.** The ransom note threatens to publish the data within 48 hours. The database held customer PII, payment records and application logins (synthetic in this lab). In production, publication would trigger breach-notification review, and the data owner would need to confirm row counts, data classification and backup age to size the loss.



Example of the exposed data: application logins stored in plaintext (synthetic lab data; password column hidden for publication).

KQL – MySQL data-directory file activity during the destructive session

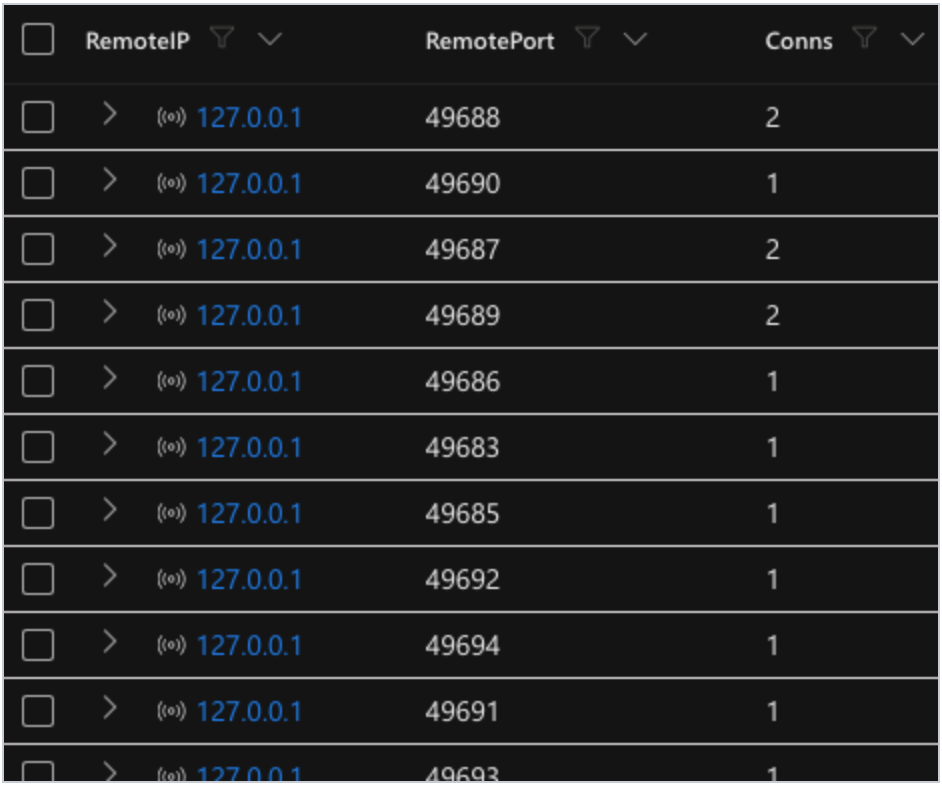
```
DeviceFileEvents
| where Timestamp between (datetime(2026-10-12 04:00:00) .. datetime(2026-10-12 05:00:00))
| where DeviceName startswith "corp-retail-gro"
| where FolderPath has @"\MySQL\MySQL Server 8.0\Data"
| where ActionType in ("FileDeleted", "FileRenamed", "FileCreated")
| project Timestamp, ActionType, FolderPath, FileName, InitiatingProcessFileName
| order by Timestamp asc
```



Defender records mysqld.exe creating the recover_your_data directory at 00:10:43, matching the ransom-note creation in the MySQL audit log.

KQL – outbound connections from the database process to non-private addresses

```
DeviceNetworkEvents
| where DeviceName startswith "corp-retail-gro"
| where InitiatingProcessCommandLine has "mysqld"
| where ActionType == "ConnectionSuccess" and not(ipv4_is_private(RemoteIP))
| summarize Conns=count() by RemoteIP, RemotePort
```



RemoteIP	RemotePort	Conns
127.0.0.1	49688	2
127.0.0.1	49690	1
127.0.0.1	49687	2
127.0.0.1	49689	2
127.0.0.1	49686	1
127.0.0.1	49683	1
127.0.0.1	49685	1
127.0.0.1	49692	1
127.0.0.1	49694	1
127.0.0.1	49691	1
127.0.0.1	49693	1

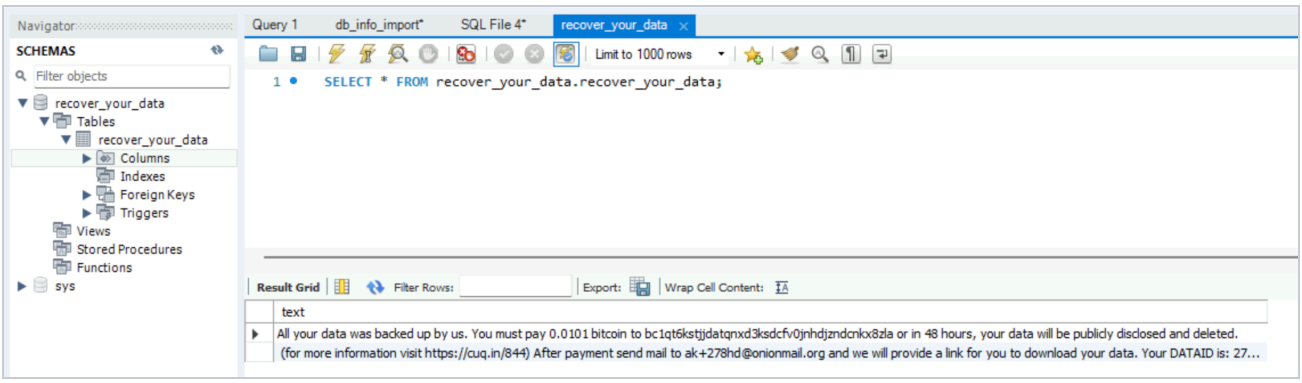
Only loopback (127.0.0.1, the server talking to itself) is returned, because ipv4_is_private() does not cover loopback. No connection from mysqld to any public address appears in the Sep 29 – Oct 18 telemetry.

4. Indicators of Compromise

The indicators below come from the ransom note and network activity in the log exports. A second set in the same ransom-note format (BTC bc1qk9kv…, ak+28t2@…, 2no[.]co/2mysql, DATAID 28T2) was supplied separately but appears in none of the seven exports, so it is listed as unverified and not used in any finding.

Type	Value	Context (source table)	Status
BTC address	`bc1qt6kstjjdatqnxd3ksdcfv0jnhdjzndcnkx8zla`	Ransom note; 0.0101 BTC demand, 48-hour deadline (MySQL queries, Oct 12 00:10:44)	Observed
Email	`ak+278hd@onionmail[.]org`	Ransom note contact (MySQL queries)	Observed
URL	`hxxps://cuq[.]in/844`	Ransom note “more information” link (MySQL queries)	Observed
Data ID	`278HD`	Ransom note (MySQL queries)	Observed

DB / table name	`RECOVER_YOUR_DATA; recover_your_data_info`	Created by attacker; repeated CREATE DATABASE Oct 13–17 (MySQL queries)	Observed
BTC address	`bc1qk9kvwhzt60u3eqcjllqlj44h0tj7w7n72apz99`	Second ransom-note set, supplied separately	Not in supplied logs
Email	`ak+28t2@onionmail[.]org`	Second ransom-note set, supplied separately	Not in supplied logs
URL	`hxxps://2no[.]co/2mysql`	Second ransom-note set, supplied separately	Not in supplied logs
Data ID	`28T2`	Second ransom-note set, supplied separately	Not in supplied logs
IP	`77.90.185.30`	Passwordless login probing as root/admin/sa from Oct 10 20:19; root logons Oct 10 21:35 – Oct 17 10:19 (MySQL auth)	Observed
IP	`77.90.185.21`	Passwordless login probing from Oct 10 21:05; one root logon Oct 14 22:12 (MySQL auth)	Observed
IP	`213.209.159.115`	Root logon Oct 11 23:29, 11 minutes after 77.90.185.30 logged in; logons through Oct 16 06:35 (MySQL auth)	Observed
IP	`64.89.163.169`	Failed root logons at 00:10:35 and 00:10:41, then successful root logon at 00:11:00 on Oct 12, around the ransom session (MySQL auth)	Observed
IP range	`64.89.163.77, .79, .80, .91, .92, .94, .154, .167, .170, .178`	Root logons Oct 13–17; several followed by CREATE DATABASE RECOVER_YOUR_DATA (MySQL auth and queries)	Observed
IP range	`64.89.163.130, .83, .140, .134, .144, .149, .153, .148`	Connection attempts and inbound connections to the host from Oct 7 (Defender network events)	Observed
IP	`139.162.70.53; 3.129.187.38; 2.27.109.208`	Inbound connections to mysqld Oct 10–16 (4, 3 and 2 connections; Defender network events)	Observed, role unconfirmed
IP	`35.205.252.77; 34.78.226.9`	Root logon Oct 14 22:09; logon as user client Oct 17 03:34 from 34.78.226.9 (MySQL auth)	Observed, role unclear
IP	`154.64.211.102; 58.56.187.158; 182.76.18.106; 38.172.56.189; 41.248.226.178; 146.19.125.182`	Successful network logons to Windows account administrator, Oct 12 20:29 – Oct 16 21:03 (DeviceLogonEvents)	Observed, link to DB attack not established
Account	`root, admin, sa (MySQL); administrator (Windows)`	Targeted accounts	Observed



Ransom note as stored in recover_your_data. The grid truncates the DATAID; the full value (278HD) is in the audit log.

KQL – IOC IPs and domains in network telemetry

```
let iocDomains = dynamic(["cuq.in", "2no.co", "onionmail.org"]);
let iocIPs = dynamic(["77.90.185.30", "77.90.185.21", "213.209.159.115", "35.205.252.77",
"34.78.226.9", "154.64.211.102", "58.56.187.158", "182.76.18.106", "38.172.56.189",
"41.248.226.178", "146.19.125.182"]);
DeviceNetworkEvents
| where DeviceName startswith "corp-retail-gro"
| where RemoteUrl has_any (iocDomains) or RemoteIP in (iocIPs) or RemoteIP startswith
"64.89.163."
| summarize Events=count(), First=min(Timestamp), Last=max(Timestamp) by DeviceName, RemoteIP,
RemoteUrl, ActionType
| order by First asc
```

DeviceName	RemoteIP	RemoteUrl	ActionType	Events	First
corp-retail-gro	64.89.163.130		ConnectionAttempt	1	Oct 7, 2026 8:54:04 PM
corp-retail-gro	64.89.163.83		ConnectionAttempt	1	Oct 9, 2026 10:02:02 PM
corp-retail-gro	64.89.163.140		InboundConnectionAcc...	1	Oct 9, 2026 11:38:27 PM
corp-retail-gro	77.90.185.30		InboundConnectionAcc...	9	Oct 10, 2026 12:00:17 AM
corp-retail-gro	64.89.163.134		ConnectionAttempt	1	Oct 10, 2026 8:11:25 PM
corp-retail-gro	77.90.185.30		ConnectionAttempt	5	Oct 10, 2026 8:19:14 PM
corp-retail-gro	77.90.185.21		InboundConnectionAcc...	7	Oct 10, 2026 9:05:21 PM
corp-retail-gro	213.209.159.115		InboundConnectionAcc...	5	Oct 11, 2026 12:13:28 AM
corp-retail-gro	64.89.163.144		InboundConnectionAcc...	1	Oct 11, 2026 9:14:49 PM
corp-retail-gro	64.89.163.169		InboundConnectionAcc...	2	Oct 12, 2026 12:10:34 AM
corp-retail-gro	64.89.163.149		InboundConnectionAcc...	1	Oct 12, 2026 3:43:42 AM

KQL – source IPs connecting to mysqld

```
DeviceNetworkEvents
| where DeviceName startswith "corp-retail-gro"
| where InitiatingProcessFileName =~ "mysqld.exe" and ActionType ==
"InboundConnectionAccepted"
| summarize Connections=count(), First=min(Timestamp), Last=max(Timestamp) by RemoteIP
| order by Connections desc
```

RemoteIP	Connections	First	Last
77.90.185.30	9	Oct 10, 2026 12:00:17 AM	Oct 17, 2026 10:19:55 AM
77.90.185.21	7	Oct 10, 2026 9:05:21 PM	Oct 16, 2026 11:49:05 PM
213.209.159.115	5	Oct 11, 2026 12:13:28 AM	Oct 16, 2026 2:22:47 PM
139.162.70.53	4	Oct 10, 2026 8:02:39 PM	Oct 16, 2026 7:28:06 AM
64.89.163.153	3	Oct 13, 2026 7:10:29 AM	Oct 16, 2026 8:43:30 PM
3.129.187.38	3	Oct 10, 2026 8:10:56 PM	Oct 16, 2026 11:36:43 PM
64.89.163.148	2	Oct 13, 2026 6:54:22 AM	Oct 16, 2026 3:05:06 AM
2.27.109.208	2	Oct 15, 2026 1:26:50 AM	Oct 16, 2026 3:00:10 AM

5. Timeline

Time (2026)	Event	Source
Sep 29 20:58	Defender telemetry begins. mysqld is already listening on 0.0.0.0:3306.	DeviceNetworkEvents
Oct 7 20:54	First connection attempt to the host from the 64.89.163.x range (64.89.163.130).	DeviceNetworkEvents
Oct 7 23:37	First public inbound connection accepted by mysqld on port 3306 (229 in total).	DeviceNetworkEvents
Oct 9 22:12	Windows administrator network logon failures begin (309 failures from 63 sources through Oct 17).	DeviceLogonEvents
Oct 10 19:52	Five failed root logons from localhost, then success at 19:52:49. Purpose not determined.	MySQL audit
Oct 10 20:19	First external passwordless login attempts as root/admin/sa from 77.90.185.30; 77.90.185.21 from 21:05.	MySQL audit
Oct 10 21:35	**Initial access:** first external root logon (77.90.185.30).	MySQL audit
Oct 11 23:18	New probe burst from 77.90.185.30, root logon 23:18:47; root logon from 213.209.159.115 at 23:29:28.	MySQL audit
Oct 12 00:10:35–41	Two failed root logons from 64.89.163.169.	MySQL audit

Oct 12 00:10:43–44	**Ransom note:** CREATE DATABASE/TABLE RECOVER_YOUR_DATA, two INSERTs (0.0101 BTC, 48h, DATAID 278HD). Defender records mysqld.exe creating the recover_your_data folder at 00:10:43.	MySQL audit; DeviceFileEvents
Oct 12 00:10:45–55	GRANT CREATE, DROP ON *.* TO root@%; schema and size queries on the three databases.	MySQL audit
Oct 12 00:10:56–57	**Destruction:** DROP DATABASE on bby_corp, sakila, world, and the note database.	MySQL audit
Oct 12 00:10:57–58	Note database recreated and note inserted again.	MySQL audit
Oct 12 00:10:59	PURGE BINARY LOGS, RESET MASTER.	MySQL audit
Oct 12 00:11:00–01	REVOKE ALL / GRANT SHUTDOWN; long-string JSON_SCHEMA_VALID call (purpose unknown); SHUTDOWN. Root logon from 64.89.163.169 logged at 00:11:00.	MySQL audit
Oct 12 18:23	MySQL reachable again: root logon from 77.90.185.30.	MySQL audit
Oct 12 20:29	First successful Windows administrator network logon (154.64.211.102).	DeviceLogonEvents
Oct 13 10:33 – Oct 17 14:38	CREATE DATABASE RECOVER_YOUR_DATA re-run 22 times, several coinciding with root logons from 64.89.163.x.	MySQL audit
Oct 14 11:43 – Oct 16 21:03	Further successful Windows administrator logons from external IPs.	DeviceLogonEvents
Oct 14 22:09 / Oct 17 03:34	Logons as user client that failed the authentication-protocol handshake; role not determined.	MySQL audit
Oct 17 15:26	Last MySQL audit event.	MySQL audit

KQL – host-side timeline (mysqld inbound connections and external logons)

```
let mydevice = "corp-retail-gro";
union (DeviceNetworkEvents
| where DeviceName == mydevice
| where InitiatingProcessFileName =~ "mysqld.exe" and ActionType ==
"InboundConnectionAccepted"
| project Timestamp, Kind="mysqld inbound", Detail=strcat(RemoteIP, " -> port ",
tostring(LocalPort))),
(DeviceLogonEvents
| where DeviceName == mydevice
| where ActionType == "LogonSuccess" and isnotempty(RemoteIP)
| project Timestamp, Kind="Windows logon", Detail=strcat(AccountName, "@", RemoteIP))
| order by Timestamp asc
```

Timestamp	Kind	Detail
Oct 12, 2026 12:28...	mysqld inbound	94.231.206.111 -> port ...
Oct 12, 2026 12:28...	mysqld inbound	94.231.206.38 -> port 3...
Oct 12, 2026 12:33...	mysqld inbound	45.79.207.252 -> port 3...
Oct 12, 2026 12:37...	mysqld inbound	77.90.185.30 -> port 3306
Oct 12, 2026 12:55...	mysqld inbound	139.162.70.53 -> port 3...
Oct 12, 2026 1:32:...	mysqld inbound	45.79.115.59 -> port 3306
Oct 12, 2026 1:46:...	mysqld inbound	::ffff:91.196.152.3 -> por...
Oct 12, 2026 1:46:...	mysqld inbound	::ffff:91.196.152.4 -> por...
Oct 12, 2026 3:19:...	mysqld inbound	34.52.186.138 -> port 3...

First rows of the result, sorted by time.

KQL – Windows logon pressure and successes

```
DeviceLogonEvents
| where DeviceName == "corp-retail-gro"
| where AccountName =~ "administrator" and isnotempty(RemoteIP)
| summarize Failed=countif(ActionType=="LogonFailed"),
Success=countif(ActionType=="LogonSuccess"),
            First=min(Timestamp), Last=max(Timestamp) by RemoteIP
| order by Success desc, Failed desc
```

RemoteIP	Failed	Success	First	Last
10.0.8.4	0	3	Oct 17, 2026 7:36:15 PM	Oct 17, 2026 7:36:17 PM
182.76.18.106	0	2	Oct 14, 2026 11:43:09 AM	Oct 14, 2026 2:58:23 PM
154.64.211.102	2	1	Oct 12, 2026 8:29:20 PM	Oct 12, 2026 8:29:25 PM
58.56.187.158	2	1	Oct 12, 2026 11:42:14 PM	Oct 12, 2026 11:42:29 PM
38.172.56.189	0	1	Oct 14, 2026 3:01:03 PM	Oct 14, 2026 3:01:03 PM
41.248.226.178	0	1	Oct 16, 2026 9:41:02 AM	Oct 16, 2026 9:41:02 AM
146.19.125.182	0	1	Oct 16, 2026 9:03:03 PM	Oct 16, 2026 9:03:03 PM
80.66.83.43	40	0	Oct 11, 2026 2:45:06 PM	Oct 11, 2026 3:12:59 PM

Seven successful logons come from six external addresses. The three logons from the internal address 10.0.8.4 (Oct 17 19:36) are excluded as non-external; the registry entries that follow them are OneDrive and Edge first-run settings.

6. Root Cause / Attack Vector

Most likely: remote login to MySQL as root over the internet with a credential that worked on the first attempt. All 461 failed external attempts were passwordless (`using password: NO`) and no wrong-password attempt appears, so the credential was probably already known, reused or empty. Defender shows mysqld listening on all interfaces (0.0.0.0:3306) from Sep 29 and accepting public inbound connections from Oct 7 (229 events on port 3306), and MySQL allowed root to log in remotely. The first external root logon came 76 minutes after the first MySQL login attempt; the destructive session followed about 26.5 hours later.

Question	Answer
Which credential worked?	The root password was valid on the first attempt. All 461 failed external attempts were passwordless and no wrong-password attempt precedes the first successful logon, so the attacker already held the credential (leaked, reused or empty). The audit log does not record passwords, so the exact value is not shown.
Who ran the destructive session?	64.89.163.169. It failed twice at 00:10:35 and 00:10:41, then logged in at 00:11:00, matching the destructive window. Connection IDs 92–122 have no logon row in the auth export, so the link rests on timing and source address.
One actor or several?	Consistent with one operator using several addresses (77.90.185.x, 213.209.159.115, 64.89.163.x). All followed the same root login pattern, and the ransom-note database was re-created 22 times through Oct 17. The 35.205 and 34.78 ranges are lower confidence.

Was the Windows host breached?	Yes, at account level. Windows administrator was heavily guessed over the network (309 failed attempts from 63 sources since Oct 9), and seven external logons from six addresses then succeeded from Oct 12 20:29. No malicious process, file or persistence followed in Defender data, and nothing ties these logons to the database attack.
Data theft?	No evidence of theft. The audit log shows no reads of business tables, and Defender shows no connection from mysqld to a public address across Sep 29 – Oct 18. Network events record connections, not bytes, so theft over an inbound session cannot be fully excluded (see Impact).

KQL – how exposed was MySQL?

```
DeviceNetworkEvents
| where DeviceName == "corp-retail-gro"
| where InitiatingProcessFileName =~ "mysqld.exe"
| where ActionType in ("ListeningConnectionCreated", "InboundConnectionAccepted")
| summarize Events=count(), First=min(Timestamp) by ActionType, LocalIP, LocalPort,
RemoteIPType
| order by Events desc
```

ActionType	LocalIP	LocalPort	RemoteIPType	Events	First
InboundConnectio...	10.3.0.19	3306	Public	229	Oct 7, 2026 11:37:56 PM
InboundConnectio...	::ffff:10.3.0.19	33060	FourToSixMapping	46	Oct 9, 2026 9:20:44 PM
ListeningConnecti...	0.0.0.0	3306		13	Sep 29, 2026 8:58:15 PM
ListeningConnecti...	::	33060		7	Sep 29, 2026 8:58:14 PM
ListeningConnecti...	127.0.0.1	49688		2	Oct 6, 2026 5:03:21 AM
ListeningConnecti...	127.0.0.1	49689		2	Oct 3, 2026 7:40:17 PM
ListeningConnecti...	127.0.0.1	49687		2	Oct 3, 2026 7:40:17 PM
ListeningConnecti...	127.0.0.1	49690		1	Oct 14, 2026 4:58:46 AM
ListeningConnecti...	127.0.0.1	49686		1	Oct 6, 2026 5:03:21 AM

mysqld listens on 0.0.0.0:3306 from Sep 29 and accepted 229 inbound connections from public addresses starting Oct 7.

KQL – guessing pattern by account (Windows logons)

```
DeviceLogonEvents
| where DeviceName =~ "corp-retail-gro"
| where ActionType == "LogonFailed"
| summarize Attempts = count(), SourceIPs = dcount(RemoteIP), First = min(Timestamp), Last =
max(Timestamp) by DeviceName, AccountName, LogonType
| order by Attempts desc
| project DeviceName, AccountName, LogonType, Attempts, SourceIPs, First, Last
```

DeviceName	AccountName	LogonType	Attempts	SourceIPs	First	Last
corp-retail-gro	administrator	Network	309	63	Oct 9, 2026 10:12:06 PM	Oct 17, 2026
corp-retail-gro	admin	Network	187	13	Oct 9, 2026 10:11:45 PM	Oct 16, 2026
corp-retail-gro	azureuser	Network	57	5	Oct 9, 2026 10:11:02 PM	Oct 17, 2026
corp-retail-gro	user	Network	40	4	Oct 9, 2026 10:12:27 PM	Oct 15, 2026
corp-retail-gro	bby_retail	Network	27	5	Oct 18, 2026 12:05:02 PM	Oct 18, 2026
corp-retail-gro	student	Network	21	2	Oct 9, 2026 10:11:23 PM	Oct 12, 2026

7. Response Actions

Backup: the data was backed up before the attack, so recovery does not depend on the attacker.

Containment (recommended, do first)

- Block inbound MySQL from the internet at the network security group or host firewall; allow only named application hosts.
- Block the source addresses in Section 4 and disable remote root (`root@%`).
- Reset the Windows administrator password, restrict Remote Desktop to a VPN or bastion, and review the seven external logons.
- Snapshot the VM and export all MySQL and Defender logs before any change.

Eradication

- Review `mysql.user`, plugins and user-defined functions for accounts or code added outside the audit window; the export shows no `CREATE USER`, `INSTALL PLUGIN` or file-write statements, but it covers only audited queries.
- Investigate the long `JSON_SCHEMA_VALID` statement and the `client` logons (Oct 14, Oct 17) as possible exploit or probe activity.
- Rotate every credential stored on or reachable from this host.

Recovery

- Restore bby_corp from the pre-incident backup and validate it before reconnecting applications.
- Binary logs were purged, so changes made after the backup was taken cannot be replayed from this server.
- Whether to engage with the extortion demand is a leadership and legal decision; the logs do not show that the attacker holds a copy of the data.

KQL – mysqld child processes and account or dump tooling

```
DeviceProcessEvents
| where Timestamp > datetime(2026-10-10)
| where DeviceName == "corp-retail-gro"
| where InitiatingProcessFileName =~ "mysqld.exe"
    or FileName in~ ("mysql.exe", "mysqldump.exe", "net.exe", "net1.exe")
    or ProcessCommandLine has_any ("net user", "net localgroup", "INTO OUTFILE")
| project Timestamp, AccountName, FileName, ProcessCommandLine, InitiatingProcessFileName
| order by Timestamp asc
```

Timestamp	AccountName	FileName	ProcessCommandLi...	InitiatingProcessFil...
Oct 10, 2026 12:10...	system	cmd.exe	cmd.exe /C "for /f "deli...	mssense.exe
Oct 10, 2026 12:10...	system	cmd.exe	cmd.exe /c net localgro...	cmd.exe
Oct 10, 2026 12:10...	system	net.exe	net localgroup	cmd.exe
Oct 10, 2026 12:10...	system	net1.exe	net1 localgroup	net.exe
Oct 10, 2026 12:10...	system	net1.exe	net1 localgroup "Access...	net.exe
Oct 10, 2026 12:10...	system	net1.exe	net1 localgroup "Admin...	net.exe
Oct 10, 2026 12:10...	system	net1.exe	net1 localgroup "Backu...	net.exe

Results are SYSTEM-account net localgroup lookups on Oct 10, with the Defender sensor (mssense.exe) at the start of the first chain. No mysql.exe, mysqldump.exe, INTO OUTFILE or net user activity.

KQL – host-side persistence check

```
let MyDevice = "corp-retail-gro";
DeviceRegistryEvents
| where DeviceName startswith MyDevice
| where RegistryKey has_any (@"\CurrentVersion\Run", @"\RunOnce", @"\Services")
| where InitiatingProcessAccountName !in~ ("system")
| project TimeGenerated, InitiatingProcessAccountName, RegistryKey, RegistryValueName,
RegistryValueData
| order by TimeGenerated asc
```

TimeGenerated	InitiatingProcessAc...	RegistryKey	RegistryValueName	RegistryValueData
Oct 10, 2026 7:47:...	bby_retail	HKEY_CURRENT_USER\S...	Delete Cached Update B...	C:\Windows\system32\c...
Oct 10, 2026 7:47:...	bby_retail	HKEY_CURRENT_USER\S...	Delete Cached Standalo...	C:\Windows\system32\c...
Oct 17, 2026 7:27:...	bby_retail	HKEY_CURRENT_USER\S...	Delete Cached Update B...	C:\Windows\system32\c...
Oct 17, 2026 7:27:...	bby_retail	HKEY_CURRENT_USER\S...	Delete Cached Standalo...	C:\Windows\system32\c...
Oct 17, 2026 7:27:...	bby_retail	HKEY_CURRENT_USER\S...	Uninstall 26.178.0913.00...	C:\Windows\system32\c...
Oct 17, 2026 7:37:...	administrator	HKEY_CURRENT_USER\S...	MicrosoftEdgeAutoLaun...	"C:\Program Files (x86)\...
Oct 17, 2026 7:38:...	administrator	HKEY_CURRENT_USER\S...	OneDrive	"C:\Users\Administrator\...
Oct 17, 2026 7:39:...	administrator	HKEY_CURRENT_USER\S...		
Oct 17, 2026 7:39:...	administrator	HKEY_CURRENT_USER\S...	Delete Cached Update B...	C:\Windows\system32\c...

Only OneDrive and Edge user-profile entries from the bby_retail and administrator accounts; no persistence entry tied to the attack.

8. Evidence

Source	Rows	Coverage (Eastern)	Used for
MySQLAudit_CL, queries (export)	812 (406 unique)	Oct 10 19:52 – Oct 17 15:26	Ransom note, DROP DATABASE, grants, binary-log purge, shutdown
MySQLAudit_CL, auth (export)	1,038 (519 unique)	Oct 10 19:52 – Oct 17 15:26	Guessing pattern, successful root logons, source IPs
DeviceLogonEvents	1,211	Sep 29 20:57 – Oct 18 12:45	Windows administrator guessing and external logons
DeviceNetworkEvents	33,214	Sep 29 20:58 – Oct 18 20:17	mysqld listener, inbound connections from attacker IPs, outbound check
DeviceFileEvents	26,251	Sep 29 20:58 – Oct 18 20:16	mysqld creating the recover_your_data folder at 00:10:43
DeviceRegistryEvents	18,150	Sep 29 20:58 – Oct 18 20:19	Persistence check: OneDrive and Edge entries only
DeviceProcessEvents	14,027	Sep 29 20:58 – Oct 18 20:19	Child-process check: SYSTEM net localgroup lookups only

Coverage gaps: the audit export has no authentication-method detail and lacks the successful logon for the destructive connections; both MySQL exports are duplicated; the Defender device name differs from the MySQL host name (truncated). All KQL in this report runs in Defender Advanced Hunting. The MySQL audit statements cited in the timeline come from the Log Analytics export and cannot be queried from Advanced Hunting.

KQL – confirm the data coverage windows

```
union withsource=Table DeviceLogonEvents, DeviceNetworkEvents, DeviceFileEvents,
DeviceRegistryEvents, DeviceProcessEvents
| where DeviceName startswith "corp-retail-gro"
| summarize Rows=count(), First=min(Timestamp), Last=max(Timestamp) by Table
```

Table	Rows	First	Last
DeviceLogonEvents	1211	Sep 29, 2026 8:57:52 PM	Oct 18, 2026 12:45:20 PM
DeviceFileEvents	26251	Sep 29, 2026 8:58:17 PM	Oct 18, 2026 8:16:57 PM
DeviceProcessEve...	14027	Sep 29, 2026 8:58:14 PM	Oct 18, 2026 8:19:32 PM
DeviceRegistryEve...	18150	Sep 29, 2026 8:58:14 PM	Oct 18, 2026 8:19:35 PM
DeviceNetworkEve...	33214	Sep 29, 2026 8:58:14 PM	Oct 18, 2026 8:17:28 PM

9. Lessons Learned / Recommendations

1. **Take MySQL off the internet (immediate).** Bind it to a private address and allow only named application hosts or a VPN. This single control would have stopped the database attack.
2. **Remove remote root and fix credentials (immediate).** Use unique, long credentials, per-application accounts without DROP, GRANT or SHUTDOWN, and enable MySQL connection-control or lockout so guessing is throttled.
3. **Close Remote Desktop exposure (this week).** Require VPN or a bastion for the Windows administrator account, rename or disable it, and review the seven external logons already recorded.
4. **Make backups survive an attacker with root (this week).** Keep immutable, off-host backups, test a restore of bby_corp, and ship binary logs to separate storage so PURGE BINARY LOGS cannot erase them.
5. **Alert on the signals this attack produced (this month).** Rule one: a successful DB logon from an address with prior failures. Rule two: DROP DATABASE, PURGE BINARY LOGS, RESET MASTER, SHUTDOWN, or a privilege change on root. Root logons and note-database re-creation continued for five days after the note was written.
6. **Close logging gaps (this month).** Onboard database hosts to Defender before an incident, log full multi-line query text and the authentication method, and stop duplicate ingestion into MySQLAudit_CL.